

ESM Credit LOS — API Surface

All credit endpoints are mounted under `/api/v1/credit` via `backend/src/routes/index.ts:95` → `backend/src/credit/routes/credit.routes.ts`. The master router defines the grouping, auth gates, and domain mounts below.

> Every domain below is a sub-router in `backend/src/credit/routes/*.routes.ts`. For a full endpoint-by-endpoint listing, read the individual route files — this doc gives the authoritative map of what exists and where.

1. Global gates (applied in the master router)

Scope	Gate	Notes
All module routes	<code>`requireFeatureFlag('credit:module')`</code>	Toggles the entire module; cached 60s
All module routes	<code>`authenticate`</code>	JWT required
App-scoped routes	<code>`applyRmScope()`</code> + <code>`requireApplicationAccess()`</code>	Mounted once at <code>`/applications/:applicationId`</code> (line 242); inherited by all nested routers. Out-of-scope reads → 404
Domain routes	<code>`requirePermission('credit:*')`</code>	Per-endpoint RBAC
Admin mutations	<code>`requireMfa`</code>	e.g. feature-flag mutations
Service-to-service	<code>`requireServiceApiKey`</code>	AV-status callback (unauthenticated by design)

2. Master-router inline endpoints (not in a sub-router)

- `GET /feature-flags/public` — {flags, integrations} for frontend tab/feature visibility (`credit:read`).
- `GET /feature-flags` — admin list (`credit:admin`).
- `PATCH /feature-flags/:key` — toggle a flag (`credit:admin` + MFA).
- `PATCH /credit-documents/:id/av-status` — AV-scanner callback (`requireServiceApiKey`, unauthenticated, above the auth gate).
- `GET /health` — module health (`credit:read`).
- `GET /applications/:appId/ca-memo/preview, /ca-memo` — CA memo PDF (`credit:read`).
- `GET /applications/:appId/approval-pack` — approval pack (`credit:read`).
- `POST/GET /applications/:appId/ca-memo-versions..., /latest, /locked, /:versionNumber, /lock, /unlock` — memo version management (`credit:write/credit:read/credit:admin`).
- `GET /applications/:id/lane, POST /applications/:id/lane, GET /applications/:id/tabs` — processing lane + tab routing (`credit:read/credit:write`).

3. Domain mounts

Borrowers & parties

Mount	Domain
<code>`/borrowers/duplicate-exceptions`</code>	<code>borrowerDuplicateException</code>

Mount	Domain
`/borrowers`	borrowerProfile, director, fatcaCrs, shareholder, ubo, financial
`/related-party-groups`	relatedPartyGroup
`/branches`	branch

Documents

creditDocumentRoutes mounted at root (e.g. /credit-documents/...). CA-memo endpoints inline (see §2).

Applications (the core)

Mount	Domain
`/applications`	application (list/create/update/transition/draft/clone), applicationFacility, applicationParty, requestItem, exposureSummary, externalRating, ecl, projection, sensitivityScenario, scoring, collateral, guarantee, condition, monitoring, bureauCheck, qualitativeAssessment, retailIncome, bureauChecklist, industryAssessment, riskAssessment, rmdIssue, esg, sicr, signoff, profitability, walletShare, accountUtilisation, disbursement, pricing, loo, rejection, creditAi

Approval & committee

Mount	Domain
`/approvals` (root `approvalRoutes`)	approval, policyExplainer
`/committee`	committee
`/score-overrides`	scoreOverride
`/delegation`	delegation
`/signoff` (via applications)	applicationSignoff

Scoring & rating

/scorecards, /scorecard-versions, /score-runs, /applications (scoring), /rating-bands, /sme (smeFinancial). Borrower risk: borrowerRiskRoutes (root).

Financials

/financials, /borrowers (financial). Plus CA-memo-phase-4: /applications (profitability, walletShare, keyCounterparty, accountUtilisation).

Ops & governance

Mount	Domain
`/dashboard`	dashboard
`/reports`	reports
`/monitoring` (+ `/applications`)	monitoring, monitoringItem
`/sla`	creditSla

Mount	Domain
`/policy-limits`	policyLimit
`/fx-rates`	fxRate
`/security`	security
`/deviations`	deviation
`/consent`	consent
`/str`	str (restricted — tipping-off risk)
`/mfa`	mfa
`/webhooks`	webhook
`/collateral`	collateralItem
`/conditions`	conditionItem

Data protection & audit (mounted at root /)

dlpRoutes (export tokens + protected exports), creditRuleConfigRoutes, amlRescreenRoutes, commentRoutes. Plus creditRecommendationRoutes and borrowerRiskRoutes.

4. Route/controller conventions

- **Controllers** live in backend/src/credit/controllers/, one per domain, thin (validate → call service → respond).
- **Validators** in backend/src/credit/validators/ (Joi), applied via validate(...) middleware.
- **Transition endpoints** use requireTransitionPermission (in creditApplication.routes.ts) which maps the request action to a permission tier; unknown actions default to credit:approve.
- **UUID params** validated via validateUUID; application-scoped paths validated for RM access.

5. RBAC permission surface (credit:*)

The module uses a fine-grained permission set. The full set spans both coarse tiers and per-domain capabilities. Core tiers used by the state machine and routes:

credit:read · credit:write · credit:create · credit:approve · credit:disburse · credit:admin

Plus domain capabilities (examples): credit:borrowers, credit:collateral, credit:committee, credit:dlp, credit:str, credit:consent, credit:deviations, credit:exposure, credit:reports, credit:dashboard, credit:scorecard, credit:rating, etc.

> **Important:** permissions are loaded with the user in the auth middleware and enforced via requirePermission. If you add a new endpoint, gate it with the most specific credit:* permission that fits; do not widen to credit:read/credit:admin by default.

6. How to enumerate the full endpoint list

The quickest accurate way to enumerate every endpoint is to scan each *.routes.ts file in backend/src/credit/routes/ for router method calls (router.get/post/patch/delete/put) and combine with the mount prefixes in credit.routes.ts. A grep -rn "router\\.\\(get\\|post\\|patch\\|put\\|delete\\)" backend/src/credit/routes/ gives the raw method+path list.